Práctica S11 - Seguridad en PharmaSoft

Luis P. II | Rama feature/seguridad-frontend-suarez | 22 de octubre de 2026

Objetivo. Integrar autenticación JWT, persistencia y vencimiento de sesión, rutas protegidas y visibilidad de menú y acciones según permisos.

Resultado de la verificación

La rama conserva el trabajo S9 y añade login, sesión, interceptores, guards y controles por permisos. La compilación Angular finalizó correctamente. Se verificaron en la SPA local los roles admin, almacenero y supervisor, además de la expiración automática de 60 segundos con retorno a la ruta previa. El backend quedó nuevamente en su configuración normal de 60 minutos.

Matriz de pruebas de la guía

N.º	Prueba	Resultado	Descripción breve / evidencia observada
1	Ruta sin sesión	Verificada	/ventas redirigió al login y conservó returnUrl=/ventas.
2	Login vacío	Verificada	Mostró las validaciones locales de usuario y contraseña.
3	Admin con clave incorrecta	Verificada	Permaneció en login con el mensaje genérico de credenciales.
4	Usuario inactivo	Pendiente	El mensaje genérico apareció, pero no se confirmó una clave válida para distinguir cuenta deshabilitada.
5	Login vendedor y retorno	Pendiente	vendedor / Vendedor2026* no autenticó en la base local actual; falta confirmar la clave vigente.
6	Bearer en consulta protegida	Verificada	La sesión de almacén cargó productos desde el endpoint protegido.
7	sessionStorage	Verificada en código	AuthService persiste pharmasoft.sesion con token, permisos y vencimiento.
8	Recarga F5	Verificada	La sesión de almacén se mantuvo en /productos y la lista volvió a cargar.
9	Vendedor sin acciones de escritura	Pendiente	Falta una sesión vendedor válida para comprobar botones y columna Acciones.
10	Vendedor abre /productos/nuevo	Pendiente	Falta una sesión vendedor válida para verificar el bloqueo por permiso.
11	Sesión abre /login	Verificada	La navegación redirigió a /inicio mientras la sesión seguía activa.
12	Cerrar sesión	Verificada	El botón llevó al login; el servicio elimina la clave de sesión.
13	Almacenero abre /ventas	Verificada	Ventas no apareció en el menú y la ruta directa mostró Acceso denegado.
14	Supervisor y edición	Verificada	Vio Ventas y las acciones Nuevo producto, Editar y Dar de baja.
15	Token alterado	Pendiente	Falta modificar el token guardado y verificar la respuesta 401 desde la SPA.
16	Expiración de 1 minuto	Verificada	La sesión venció, mostró aviso y guardó /ventas para volver; backend restaurado a 60 minutos.

Pendientes para cerrar la evidencia

Las pruebas 4, 5, 9, 10 y 15 requieren repetir el flujo con la clave vigente del usuario vendedor/inactivo o alterar el token desde el almacenamiento del navegador. No se marcan como aprobadas. Este informe registra resultados observados; las capturas de pantalla del paso 11 todavía deben incorporarse para que el PDF cumpla la entrega completa de la guía.